

CIBERSEGURIDAD DEFENSIVA

Gestión de Incidentes y Playbooks de SOC

Resumen de Clase — Edición sincronizada con playbooks v3.0

Elaborado por	Asistente de Ciberseguridad Defensiva (Blue Team)
Fecha	Junio 2026
Versión	3.0 — Sincronizada con SOC-IR-041 v1.0 · SOC-IR-042 v2.0 · SOC-IR-043 v1.0
Cubre	Phishing (041) · Ransomware (042) · DDoS (043)
Marcos	NIST SP 800-61 Rev. 2 · MITRE ATT&CK · SANS · ISO/IEC 27035

"Un incidente bien gestionado no es el que no ocurrió. Es el que el equipo supo cómo responder."

1. El Punto de Partida: Un Playbook Incompleto

Todo empezó con el Playbook SOC-IR-042 v1.0, un procedimiento real diseñado para responder ante incidentes de ransomware. Era técnicamente sólido en lo que cubría, pero presentaba una brecha crítica: solo describía dos de las seis fases que un incidente completo requiere — Detección y Contención. Las fases de Preparación, Erradicación, Recuperación y Lecciones Aprendidas estaban ausentes por completo.

! Analogía clave: Es como un manual de primeros auxilios que explica cómo reconocer una fractura ósea, pero no indica cómo entablillarla, transportar al paciente al hospital ni hacer el seguimiento posterior. Funciona para el diagnóstico inicial, pero deja al equipo sin guía en el momento más crítico.

1.1 Las Nueve Brechas Identificadas en SOC-IR-042 v1.0

El análisis sistemático del playbook original reveló nueve brechas que comprometían su efectividad operativa:

#	Brecha	Impacto operativo
1	Fase de Preparación ausente	Sin backups verificados ni herramientas preconfiguradas, la respuesta parte de cero
2	Sin triggers de activación definidos	Activación tardía o inconsistente según criterio del analista
3	Roles y responsables no asignados	Ambigüedad de mando genera retrasos durante el incidente
4	Contención limitada (solo aislamiento manual)	Sin automatización SOAR, el host puede seguir propagando durante minutos
5	Fase de Erradicación ausente	El malware puede persistir tras el aparente cierre del incidente
6	Recuperación no documentada	Restauración desde backups sin criterios de verificación
7	Sin mapeo MITRE ATT&CK	Imposible auditar cobertura de detección
8	Criterios de escalado ausentes	Incidentes mayores gestionados con urgencia de incidente menor
9	Sin métricas de cierre (MTTD/MTTC/MTTR)	No hay forma de medir si el equipo mejoró tras cada incidente

2. El SOC y la Función Crítica de los Playbooks

2.1 ¿Qué es un SOC?

Un Security Operations Center (SOC) es el equipo responsable de monitorizar, detectar y responder a incidentes de seguridad en tiempo real, operando 24 horas al día, 7 días a la semana, 365 días al año. Funciona como una sala de guardia permanente: cuando algo malo ocurre en la infraestructura digital de la organización, el SOC debe reaccionar con rapidez y criterio.

Los analistas del SOC se organizan en niveles de especialización:

- **L1 — Analista de alertas:** Primera línea. Monitoriza dashboards, clasifica alertas y escala al L2 cuando se confirma un incidente real.
- **L2 — Analista de incidentes:** Investiga en profundidad, ejecuta el playbook, coordina la contención y erradicación.
- **L3 — Especialista senior / Threat Hunter:** Analiza incidentes complejos, realiza threat hunting proactivo y actualiza los playbooks.
- **IR Lead:** Coordina la respuesta completa, gestiona la comunicación con el CISO y stakeholders externos. Autoriza acciones de alto impacto como el BGP blackholing en DDoS.

2.2 Por Qué los Playbooks son Indispensables

Durante un incidente real — ransomware cifrando archivos a las 3 de la mañana, un ataque DDoS tumbando el servicio web en plena campaña de ventas — no hay tiempo para pensar desde cero. Cada segundo de indecisión puede traducirse en datos cifrados, sistemas comprometidos o pérdida de ingresos.

Los playbooks existen precisamente para ese momento: son procedimientos escritos de antemano que especifican exactamente qué hacer, en qué orden, quién lo ejecuta y cuándo escalar. Convierten una situación de pánico potencial en una secuencia de pasos ejecutables y verificables.

→ La diferencia entre un equipo con playbooks bien diseñados y uno sin ellos puede ser la diferencia entre contener el daño en dos horas o en dos semanas, con las correspondientes consecuencias operativas, legales y reputacionales.

2.3 Características de un Playbook de Calidad

No todo documento que lleva el nombre 'playbook' cumple su función bajo presión. Un playbook de calidad debe reunir las siguientes características:

1. **Accionable:** Cada paso debe poder ejecutarse directamente, sin necesidad de interpretación adicional.
2. **Específico:** Nombra herramientas concretas, comandos exactos y umbrales numéricos (no 'analizar los logs', sino 'buscar Event ID 4688 en Splunk con query X en las últimas 4 horas').
3. **Completo:** Cubre las seis fases del ciclo NIST, sin omitir Erradicación ni Lecciones Aprendidas.
4. **Verificable:** Incluye checkboxes y criterios de éxito medibles para cada paso.
5. **Mantenido:** Se revisa y actualiza después de cada incidente real y con periodicidad semestral.

2.4 El Playbook Operativo: Diseñado para las 3 AM

El playbook operativo tiene un requisito de diseño brutal: debe ser usable bajo presión extrema, con mínimo sueño, por un analista de nivel L1 que puede llevar semanas sin gestionar un incidente de este tipo. Eso implica:

- Pasos numerados, no párrafos de explicación.
- Comandos exactos listos para copiar y pegar, no descripciones de lo que hay que buscar.
- Checkboxes para confirmar cada acción completada — el analista no debe retener estado mental.
- Tiempos de escalado explícitos: 'Si en 15 min no se confirma el tipo de ataque, escala al IR Lead'.
- Información de contacto de escalado directamente en el documento, sin depender de sistemas externos que pueden estar comprometidos.

3. El Marco de Referencia: NIST SP 800-61 Rev. 2

Todo el trabajo de documentación sigue el ciclo de vida del NIST SP 800-61 Rev. 2, publicado por el National Institute of Standards and Technology de Estados Unidos. Es el estándar de facto del sector para la gestión de incidentes de seguridad y es referenciado por regulaciones como el RGPD, la directiva NIS2 y los estándares del ENS (Esquema Nacional de Seguridad en España).

3.1 Las Seis Fases del Ciclo de Vida

Fase	Tiempo típico	Qué significa en la práctica
Preparación	Continuo (pre-incidente)	Backups verificados, equipo entrenado, herramientas configuradas y accesos SOAR preautorizados. Es la fase más descuidada y la de mayor impacto.
Detección y Análisis	0 – 30 min	Confirmar que el incidente es real (no un falso positivo), medir su alcance, clasificar tipo y severidad según matriz de criticidad.
Contención	10 seg – 2 h	Detener el daño inmediato: aislar el host, purgar el correo malicioso, redirigir el tráfico de ataque. No resuelve la causa raíz, pero evita propagación.
Erradicación	2 – 24 h	Eliminar la causa raíz: borrar el malware, rotar credenciales comprometidas, parchear la vulnerabilidad explotada, revocar accesos no autorizados.
Recuperación	1 – 72 h (ransomware) 1 – 24 h (DDoS)	Volver a la normalidad de forma controlada: restaurar desde backups verificados, monitorización reforzada post-incidente, confirmación de los dueños del negocio.
Lecciones Aprendidas	< 2 semanas post-incidente	Post-mortem blameless: ¿qué falló?, ¿qué funcionó?, actualizar el playbook, mejorar las reglas de detección. La fase más omitida y la segunda más importante.

3.2 Por Qué Importa Cada Fase

Preparación — La fase invisible

La mayor parte del trabajo de respuesta a incidentes ocurre antes del incidente. Un equipo que tiene backups inmutables verificados semanalmente, runbooks de SOAR preconfigurados y ejercicios de simulación (tabletop exercises) realizados trimestralmente, reducirá su MTTR en un factor de 5-10x respecto a un equipo que improvisa. En DDoS, esto incluye tener el servicio anti-DDoS preconfigurado para activación en menos de 15 minutos y el contacto 24/7 con el ISP documentado antes de que ocurra el primer ataque.

Erradicación — La más omitida

Es frecuente que equipos bajo presión declaren el incidente cerrado tras la contención, sin erradicar la causa raíz. El resultado es la reinfección: el atacante regresa por el mismo vector días o semanas después. La erradicación requiere confirmar que el malware fue eliminado de todos los sistemas

afectados, que todas las credenciales comprometidas fueron rotadas y que la vulnerabilidad explotada fue parcheada. En phishing, implica también revisar las reglas de reenvío automático (T1114.003) y los dispositivos MFA no autorizados en el buzón comprometido — elementos que un escaneo de endpoint estándar no detecta porque ocurren íntegramente dentro del servidor de correo.

Recuperación — Tiempos distintos por razones distintas

El playbook SOC-IR-042 (Ransomware) establece monitorización reforzada de 72 horas tras la reconexión, dado el riesgo de reinfección por artefactos no detectados. El playbook SOC-IR-043 (DDoS) establece 24 horas, porque los atacantes frecuentemente relanzan el ataque tras una pausa corta, una vez detectan que los controles de emergencia se han desactivado. Son tiempos distintos con razones operativas distintas.

Lecciones Aprendidas — El motor de mejora

El post-mortem es el mecanismo que impide que el equipo cometa los mismos errores en el siguiente incidente. Debe realizarse dentro de los 14 días posteriores al cierre, cuando la memoria es fresca, e incluir un análisis sin culpas (blameless post-mortem) que identifique fallos sistémicos, no individuales.

4. MITRE ATT&CK: El Idioma del Adversario

MITRE ATT&CK (Adversarial Tactics, Techniques & Common Knowledge) es una base de conocimiento pública, mantenida por la organización sin ánimo de lucro MITRE Corporation, que cataloga cómo atacan los adversarios reales. No es teórica: cada entrada está documentada con casos reales observados en incidentes reales. Es el idioma común de la ciberseguridad defensiva.

4.1 Estructura: Tácticas y Técnicas

ATT&CK organiza el comportamiento adversario en dos niveles:

- **Tácticas (TA):** El objetivo que el atacante intenta lograr. Ej: TA0001 Initial Access (entrar a la red), TA0002 Execution (ejecutar código), TA0040 Impact (causar daño).
- **Técnicas (T):** El método específico para lograr esa táctica. Ej: T1566 Phishing para Initial Access, T1486 Data Encrypted for Impact para el cifrado de ransomware.

4.2 Aplicaciones Prácticas para un Analista SOC

6. Saber qué buscar en los logs: Si el atacante usa T1059.001 (PowerShell), busco Sysmon Event ID 1 (creación de proceso) con líneas de comando codificadas en Base64.
7. Comunicación sin ambigüedad: Decir 'T1114.003 Email Forwarding Rule' es más preciso que 'el atacante configuró un redireccionamiento en el correo' — no da lugar a confusión.
8. Auditar cobertura de herramientas: Puedo mapear qué técnicas de un grupo de amenaza específico cubro con mi stack actual y qué brechas tengo.

4.3 Técnicas Mapeadas en los Tres Playbooks

Playbook	Técnica MITRE	Táctica	Qué detecta / previene
Phishing	T1566 Phishing	TA0001 Initial Access	Vector de entrada: correo malicioso con enlace o adjunto weaponizado
Phishing	T1566.001 Spearphishing Attachment	TA0001 Initial Access	Adjunto ejecutable o documento con macro maliciosa
Phishing	T1566.002 Spearphishing Link	TA0001 Initial Access	URL maliciosa en el cuerpo del correo
Phishing	T1114.003 Email Forwarding Rule	TA0003 Persistence	Regla de reenvío creada por el atacante en el buzón comprometido
Phishing	T1078 Valid Accounts	TA0006 Credential Access	Uso de credenciales comprometidas; requiere revocación de sesiones en IAM
Ransomware	T1059.001 PowerShell	TA0002 Execution	Comandos codificados en Base64 detectados vía Sysmon Event ID 1
Ransomware	T1486 Data Encrypted for Impact	TA0040 Impact	Cifrado masivo de archivos (extensiones modificadas)

Playbook	Técnica MITRE	Táctica	Qué detecta / previene
Ransomware	T1490 Inhibit System Recovery	TA0040 Impact	Eliminación de Shadow Copies vía vssadmin.exe
Ransomware	T1547 Boot/Logon Autostart Execution	TA0003 Persistence	Tareas programadas y claves de registro para persistencia post-infección
Ransomware	T1070 Indicator Removal	TA0005 Defense Evasion	Eliminación de logs por el atacante para dificultar el análisis forense
DDoS	T1498 Network Denial of Service	TA0040 Impact	Tráfico volumétrico que supera el baseline (Gbps / Mpps)
DDoS	T1498.001 Direct Network Flood	TA0040 Impact	UDP/ICMP flood identificado en análisis NetFlow
DDoS	T1498.002 Reflection Amplification	TA0040 Impact	Amplificación DNS/NTP detectada por el IDS
DDoS	T1499 Endpoint Denial of Service	TA0040 Impact	HTTP flood / Slowloris detectado en capa 7 por el WAF
DDoS	T1584 Compromise Infrastructure	TA0042 Resource Dev.	IPs de botnets y reflectores identificados en logs para ACLs de borde

5. Los Tres Tipos de Incidente: Análisis Detallado

5.1 Ransomware — SOC-IR-042

- ★ Impacto: CRÍTICO. Puede paralizar operaciones completas en minutos. Implica consecuencias legales, financieras y reputacionales.

El ransomware es el tipo de incidente con mayor impacto operativo inmediato. Desde que el malware inicia el proceso de cifrado, cada segundo supone más datos perdidos. La cadena de ataque típica sigue este patrón:

9. Acceso inicial vía phishing (T1566) o explotación de RDP/VPN expuesto.
10. Movimiento lateral para maximizar el alcance antes de activar el cifrado.
11. Eliminación de Shadow Copies (T1490) para impedir restauración rápida.
12. Cifrado masivo de archivos (T1486) con extensión modificada.
13. Nota de rescate y contacto con canal de pago (usualmente Tor + criptomoneda).

Contención automatizada vía SOAR (< 10 segundos)

El corazón del playbook SOC-IR-042 v2.0 es la contención automatizada: el SOAR aísla el host comprometido en menos de 10 segundos mediante API del EDR, manteniendo activo el canal TLS de gestión con la consola del SOC. El punto de control crítico es: ¿aislamiento confirmado correctamente? Si la API del SOAR falla (timeout o error de autenticación), el Analista L2 ejecuta la contención manual: deshabilitar la cuenta comprometida en el directorio activo, bloquear el acceso VPN/RDP del segmento afectado y coordinar con el NOC el aislamiento físico del puerto de red.

Preservación de evidencia forense

Antes de cualquier acción de remediación adicional, el Analista L2/L3 captura una imagen forense o volcado de memoria del host afectado cuando sea viable, conforme a la cadena de custodia interna. Esta evidencia es necesaria para sostener una eventual investigación posterior, una reclamación de seguro cibernético o un procedimiento legal.

Postura ante el rescate

- × La organización NO inicia ni autoriza negociación o pago de rescate sin autorización expresa y documentada de Dirección + Legal + CISO de forma simultánea. Ningún analista ni IR Lead está autorizado a realizar pagos unilaterales. Razones: (1) el pago no garantiza la recuperación de los datos, (2) financia grupos criminales, (3) puede constituir infracción legal si el grupo está sancionado internacionalmente (regulación OFAC de EE. UU.).

Involucración de stakeholders no técnicos

- CISO: Autoriza la declaración de incidente mayor y gestiona la comunicación ejecutiva.
- Legal / DPO: Determina las obligaciones de notificación regulatoria (RGPD: máximo 72 horas desde el conocimiento del incidente).
- Dirección General: Decisión final sobre la postura ante el rescate, con asesoría legal previa.
- Comunicación / RRPP: Gestiona la comunicación externa bajo aprobación de Dirección. Ningún miembro técnico realiza declaraciones externas.

5.2 Phishing — SOC-IR-041

- El vector de entrada más frecuente en incidentes graves. La clave está en la bifurcación temprana: tratarlos igual genera demasiada fricción en el caso fácil o demasiado poco rigor en el caso grave.

El diseño del playbook SOC-IR-041 establece una bifurcación crítica desde el triage inicial. El punto de decisión es si el EDR o el proxy confirman interacción del usuario con el contenido malicioso:

	Escenario A — Bajo riesgo	Escenario B — Alto riesgo
Situación	Usuario reportó el correo sin interactuar	Usuario hizo clic, ejecutó adjunto o ingresó credenciales
Urgencia	Media — resolución < 4 horas	Alta — acciones de contención < 15 minutos
Acción inmediata	Purgar el correo de TODOS los buzones + bloquear remitente, dominio e IP	Deshabilitar cuenta + revocar todas las sesiones y tokens en IAM
Punto de control crítico	¿Purga confirmada en el 100% de buzones? Si NO: eliminación manual buzón por buzón (IT/Helpdesk)	¿Hubo ingreso de credenciales o malware confirmado? Si SÍ: aislar endpoint + preservar evidencia forense
Erradicación específica	Bloqueo de IOCs en SEG y firewall perimetral	Revisar reglas de reenvío (T1114.003) y dispositivos MFA no autorizados registrados en el buzón
Escalado	Notificar al equipo de concienciación para refuerzo formativo	Activar respuesta completa: IR Lead + análisis forense de cuenta y endpoint

Caso especial: Business Email Compromise (BEC)

- ACCIÓN INMEDIATA ante BEC: llamada telefónica DIRECTA al responsable de Finanzas/Tesorería ANTES de abrir el ticket. La ventana para detener una transferencia bancaria puede ser de minutos. Este paso no espera al IR Lead ni al flujo estándar de ticketing.

El BEC es la variante donde el atacante, habiendo comprometido una cuenta legítima o suplantado su identidad, solicita transferencias bancarias urgentes a personal de Finanzas. Los sistemas de liquidación interbancaria procesan en tiempo real. El playbook define un canal de escalado dedicado fuera del flujo habitual: llamada directa al responsable de Tesorería con código de alerta BEC para pausar cualquier transferencia pendiente.

Comunicación con el usuario afectado

El playbook establece explícitamente que la comunicación con el usuario debe ser directa y no punitiva. El usuario que reportó el correo actuó correctamente. La disposición a reportar incidentes futuros depende de que el usuario no asocie el reporte con una sanción o juicio negativo. Un equipo que penaliza los reportes recibe menos reportes — y más incidentes que no se detectan a tiempo.

5.3 DDoS — SOC-IR-043

≠ Fundamentalmente diferente: no compromete datos ni sistemas internos. Su único objetivo es interrumpir la disponibilidad. El MTTC (tiempo hasta la mitigación activa) es la métrica más crítica, por encima del análisis forense.

Los ataques DDoS son cualitativamente distintos. No hay exfiltración, no hay cifrado, no hay persistencia. La complejidad radica en que existen tres tipos de ataque con vectores y mitigaciones completamente distintos:

Tipo	Ejemplo	Qué satura	Mitigación correcta
Volumétrico	UDP flood, amplificación DNS/NTP	Ancho de banda de red (Gbps)	Scrubbing center en nube / BGP blackholing (requiere IR Lead)
De protocolo	SYN flood, IP fragmentation	Estado del firewall / CPU de red	SYN proxy en firewall / FortiDDoS
Capa 7 (aplicación)	HTTP flood, Slowloris	Recursos del servidor web	WAF con rate limiting + CAPTCHA challenge

! Usar la herramienta equivocada puede causar una denegación de servicio AUTO-INFLIGIDA. Activar BGP blackholing contra un ataque de capa 7 bloquea a los propios usuarios legítimos. Usar CAPTCHA challenge contra un volumétrico de 100 Gbps no absorbe el ancho de banda. La clasificación del tipo de ataque es OBLIGATORIA antes de activar cualquier medida de mitigación.

BGP Blackholing: medida de último recurso con autorización obligatoria

El BGP blackholing implica aceptar la indisponibilidad total de la IP atacada como mal menor frente a la saturación del enlace. Requiere autorización explícita del IR Lead. El Analista L1 NO puede activarlo de forma autónoma. Esta medida requiere coordinación con el ISP, cuyo contacto 24/7 debe estar preestablecido y documentado como requisito de Preparación — antes de que ocurra el primer ataque.

Riesgo de relanzamiento post-ataque

Los atacantes frecuentemente relanzan el ataque tras una pausa corta, una vez detectan que los controles de emergencia se han desactivado. Por ello el playbook SOC-IR-043 establece monitorización reforzada de mínimo 24 horas tras la recuperación de servicios, antes de desactivar las medidas de emergencia.

6. El Catálogo de Documentos: Función y Audiencia

Para cada tipo de incidente se generaron tres documentos con funciones, audiencias y formatos distintos. Esta separación es intencionada: mezclar el contenido de los tres en un único documento genera un artefacto que no sirve bien a ninguna audiencia.

Documento	Audiencia primaria	Cuándo se usa	Formato clave
Informe técnico	CISO, responsable de seguridad, auditor	Previa al incidente / revisión periódica	Prosa técnica, análisis de brechas, justificación de decisiones de diseño
Playbook operativo	Analista SOC L1/L2/L3, IR Lead	Durante el incidente, 24/7	Pasos numerados, checkboxes, tablas de escalado con tiempos concretos
Diagrama de flujo	Todo el equipo SOC (pared física del SOC)	Referencia rápida durante incidente activo	Un nodo por decisión/acción, ≥ 3 opciones de herramienta por fase

6.1 El Informe Técnico: Justificación del Diseño

El informe técnico no es el playbook. Está diseñado para justificar ante la dirección por qué el playbook está diseñado como está: qué brechas existían en la versión anterior, qué decisiones de diseño se tomaron, qué marcos se siguieron y cómo se audita la cobertura de detección. Es el documento que se presenta en una revisión de seguridad o auditoría. Para el playbook de ransomware documenta las 9 brechas del v1.0. Para phishing y DDoS documenta la metodología de diseño desde cero.

6.2 El Playbook Operativo: Diseñado para las 3 AM

El playbook operativo tiene un requisito de diseño brutal: debe ser usable bajo presión extrema, con mínimo sueño, por un analista de nivel L1 que puede llevar semanas sin gestionar un incidente de este tipo. Eso implica:

- Pasos numerados, no párrafos de explicación.
- Comandos exactos listos para copiar y pegar, no descripciones de lo que hay que buscar.
- Checkboxes para confirmar cada acción completada — el analista no debe retener estado mental.
- Tiempos de escalado explícitos con destinatarios concretos.
- Información de contacto de escalado directamente en el documento, sin depender de sistemas externos que pueden estar comprometidos.

6.3 El Diagrama de Flujo: La Referencia Visual

El diagrama de flujo es la representación visual del playbook. Debe estar impreso en la pared del SOC, en formato A3 o superior. Sus características de diseño:

- Un nodo por cada decisión o acción — no nodos que agrupan múltiples pasos.

- Rombos para decisiones (sí/no), rectángulos para acciones, círculos para inicio/fin.
- Panel lateral de herramientas en cada fase con mínimo tres opciones, para equipos con distintos stacks tecnológicos.
- Código de colores por fase del ciclo NIST para orientación visual inmediata.
- Las herramientas listadas son opciones de referencia; cada organización selecciona según su stack disponible.

7. Los Nueve Elementos de un Playbook Completo

A lo largo de todo el proyecto se aplicó una checklist de nueve elementos. La presencia de todos ellos distingue un playbook profesional de un documento de intenciones. Conocerla de memoria permite auditar cualquier playbook en menos de cinco minutos.

#	Elemento	Por qué importa — y qué falla si está ausente
1	Nombre, versión y alcance	Define qué cubre el playbook y, tan importante, qué NO cubre. Sin esto, el analista puede aplicar el procedimiento equivocado a un incidente fuera de su scope.
2	Triggers de activación	Eventos concretos y medibles que activan el playbook. Sin triggers definidos, la activación es tardía (el analista espera 'estar seguro') o inconsistente (depende del criterio de cada persona).
3	Roles y responsabilidades	Quién hace qué en cada fase, con nombres de rol (no personas). La ambigüedad de mando durante un incidente genera retrasos fatales y acciones duplicadas o contradictorias.
4	Las seis fases NIST completas	Garantizan que el incidente se cierra de verdad. Sin Erradicación, el atacante puede regresar. Sin Recuperación documentada, el sistema vuelve al servicio sin verificación. Sin Lecciones Aprendidas, el equipo no mejora.
5	Acciones técnicas concretas	Evitan los procedimientos que dicen 'analizar los logs' sin especificar cuáles, con qué herramienta, qué query y qué se considera un hallazgo relevante.
6	Mapeo a MITRE ATT&CK	Hace auditable la cobertura de detección: ¿qué técnicas del atacante detecta mi stack actual? Permite identificar brechas de detección de forma sistemática.
7	Criterios de escalado con tiempos	Con destinatarios y ventanas temporales concretas. Sin esto, incidentes mayores se gestionan con urgencia de incidente menor porque nadie sabe exactamente cuándo escalar ni a quién.
8	Pautas de comunicación	Audiencias distintas (NOC, CISO, Legal, clientes externos, reguladores) necesitan tipos de información diferentes. Sin guías de comunicación, los mensajes son inconsistentes o inapropiados para la audiencia.
9	Métricas de cierre (MTTD/MTTC/MTTR)	Sin métricas, no hay forma de saber si el equipo mejoró entre un incidente y el siguiente. MTTD (detección), MTTC (contención) y MTTR (recuperación) son los KPIs estándar del sector.

KPI MTTD = Mean Time To Detect | MTTC = Mean Time To Contain | MTTR = Mean Time To Recover. Un SOC maduro los mide en todos los incidentes, los agrega mensualmente y los presenta en el informe de postura de seguridad al CISO.

8. Resumen de Herramientas por Función

Las herramientas no son el playbook, pero son lo que hace posible ejecutar cada paso. La selección de herramientas que aparece en los playbooks representa las opciones más utilizadas en el mercado enterprise. En cada organización, el analista debe conocer qué herramienta de su stack cubre cada función.

Función	Herramientas de referencia	Cuándo se usa en el incidente
Gateway de correo / SEG	Proofpoint TAP, Mimecast, Microsoft Defender for Office 365	Primera línea de defensa frente a phishing. Cuarentena automática, sandboxing de adjuntos y purga retroactiva (ZAP) de mensajes ya entregados.
EDR	CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint	Detecta y mata procesos maliciosos. Aísla el host por API en < 10 segundos (ransomware). Escaneo y limpieza post-phishing con ejecución confirmada.
SIEM	Splunk Enterprise Security, Microsoft Sentinel, Wazuh	Centraliza y correlaciona logs de host, red y aplicación. Genera las alertas que activan el playbook. Fuente primaria de evidencia forense.
SOAR	Cortex XSOAR, Shuffle, Tines	Automatiza la respuesta inicial: aislamiento < 10s, bloqueos en firewall, apertura automática de tickets, enriquecimiento de IOCs con Threat Intelligence.
IAM	Okta, Microsoft Entra ID (Azure AD)	Revoca sesiones y tokens de acceso tras un phishing con credenciales comprometidas. Revisa dispositivos MFA no autorizados. Activa MFA reforzado post-incidente.
Anti-DDoS cloud	Cloudflare Magic Transit, AWS Shield Advanced, Akamai Prolexic	Absorbe y filtra tráfico de ataque volumétrico antes de que llegue a la infraestructura. Preconfigurado para activación en < 15 minutos.
WAF	Cloudflare WAF, AWS WAF, F5 BIG-IP ASM	Filtra ataques DDoS de capa 7 (HTTP flood, Slowloris) con rate limiting, TLS fingerprinting y CAPTCHA challenge. No sirve contra ataques volumétricos.
Backup / Recuperación	Veeam, Cohesity DataProtect, Rubrik Security Cloud	Fuente de restauración ante ransomware. Debe ser inmutable (WORM) y no accesible desde la red de producción (air-gapped). Pruebas de restauración periódicas obligatorias.

Función	Herramientas de referencia	Cuándo se usa en el incidente
Forense / DFIR	Velociraptor, FTK Imager, Volatility	Imagen de disco y volcado de memoria antes de cualquier remediación (ransomware). Cadena de custodia documentada para investigación, seguro o procedimiento legal.
Threat Intelligence	VirusTotal Enterprise, Recorded Future, MISP	Enriquece IOCs (hashes, IPs, dominios) con contexto de atribución. Identifica IPs de botnets y reflectores (DDoS) y familias de ransomware conocidas.
Gestión de incidentes	TheHive, ServiceNow ITSM, Jira Service Management	Registra el incidente, coordina el equipo y centraliza la evidencia para el post-mortem y el expediente de auditoría.

9. Arquitectura de Defensa en Profundidad

Los playbooks son efectivos cuando se integran en una arquitectura de defensa en profundidad (Defense in Depth). Este principio establece que la seguridad nunca depende de un único control: si un control falla, la siguiente capa debe detectar o contener el incidente.

9.1 Las Capas de Defensa

Una arquitectura de defensa en profundidad efectiva opera en capas concéntricas, cada una con controles preventivos y detectivos:

C a p a	Nombre	Controles preventivos	Controles detectivos
1	Perímetro externo	Firewall de próxima generación (NGFW), Anti-DDoS cloud, VPN/Zero Trust Network Access	IDS/IPS, NetFlow analysis, BGP monitoring
2	Correo electrónico	SEG (filtrado anti-spam/malware), SPF/DKIM/DMARC, sandbox de adjuntos	Detección de phishing con ML, alertas de BEC
3	Red interna	Segmentación de red (VLANs), microsegmentación, listas de control de acceso	SIEM (correlación de logs de red), NDR (Network Detection & Response)
4	Endpoint	EDR con control de aplicaciones, gestión de parches, cifrado de disco	EDR (detección de comportamiento), Sysmon (Event ID 1), análisis de procesos
5	Identidad y acceso	MFA obligatorio, Privileged Access Management (PAM), política de contraseñas	Detección de anomalías de acceso (UEBA), alertas de cuentas inactivas con sesión
6	Datos	Cifrado en reposo y en tránsito, DLP (Data Loss Prevention), clasificación de datos	CASB (Cloud Access Security Broker), alertas de exfiltración

9.2 El Rol del SOC en la Arquitectura

El SOC es el cerebro de la arquitectura de defensa: no controla todas las capas directamente, pero monitoriza las señales que generan. Un SIEM bien configurado ingiere logs de todas las capas anteriores y correlaciona eventos que, individualmente, parecerían benignos pero juntos indican un ataque en progreso.

Ejemplo: un login fallido en el firewall (capa 1) seguido de un correo de phishing bloqueado (capa 2) seguido de un proceso sospechoso en un endpoint (capa 4) puede indicar un ataque dirigido. Ninguno de los tres eventos, por sí solo, activa una alerta de alta prioridad. La correlación en el SIEM los convierte en una alerta de incidente grave.

9.3 Los Playbooks como Pegamento de la Arquitectura

Sin playbooks, la arquitectura de defensa en profundidad detecta el ataque pero no sabe cómo responder. El SIEM genera la alerta, el EDR identifica el proceso malicioso, pero si el analista no tiene un procedimiento claro, la respuesta es ad hoc, inconsistente y lenta. Los playbooks son el pegamento operativo que convierte la detección en acción coordinada.

Cada herramienta de la arquitectura tiene su rol específico en los playbooks:

- **Capa 1 (Perímetro):** el firewall y el sistema anti-DDoS ejecutan los bloqueos que el SOAR les instruye automáticamente en ransomware, y son el primer punto de defensa en DDoS.
- **Capa 2 (Correo):** el SEG es la primera línea de defensa en phishing y ejecuta la purga retroactiva de correos maliciosos ya entregados.
- **Capa 4 (Endpoint):** el EDR es el actuador de la contención automatizada en ransomware, aislando el host en < 10 segundos por instrucción del SOAR.
- **Capa 5 (Identidad):** el IAM ejecuta la revocación de sesiones y tokens en phishing con credenciales comprometidas, y la revisión de dispositivos MFA no autorizados.

10. La Lección Más Importante: Tecnología + Proceso + Personas

El error más frecuente en ciberseguridad defensiva es creer que la tecnología por sí sola es suficiente. Un SIEM sin un analista que sepa interpretar sus alertas genera miles de falsos positivos que terminan siendo ignorados. Un EDR sin un proceso de respuesta documentado detecta el ransomware pero el analista no sabe qué hacer con la alerta. Un servicio anti-DDoS sin un procedimiento de activación practicado tarda 20 minutos en activarse mientras el sitio está caído.



Los playbooks son el puente entre la tecnología y las personas. Son el mecanismo que convierte herramientas poderosas en capacidades de respuesta reales. Y las lecciones aprendidas son el motor que hace que cada incidente deje al equipo un poco mejor preparado para el siguiente.

10.1 El Triángulo Imposible de Romper

La madurez de un SOC se mide por la intersección de tres dimensiones que deben desarrollarse simultáneamente:

- **Tecnología:** Las herramientas correctas, bien configuradas, bien integradas entre sí. Un SIEM que no ingiere los logs correctos no detecta nada. Un EDR sin políticas afinadas genera fatiga de alertas.
- **Proceso:** Los playbooks, las matrices de escalado, los criterios de severidad, los procedimientos de post-mortem. Sin proceso, la tecnología no tiene un marco de activación.
- **Personas:** Analistas entrenados, con ejercicios de simulación periódicos, con conocimiento real de las herramientas y con la cultura de documentar y mejorar. Sin personas formadas, el proceso no se ejecuta.

10.2 El Catálogo Construido — Resumen Final Sincronizado

Catálogo construido	Código	Documentos generados (v3.0 — sincronizado)
Playbook de Phishing	SOC-IR-041	Informe de diseño · Playbook operativo v1.0 · Diagrama de flujo granular
Playbook de Ransomware	SOC-IR-042	Informe de revisión (9 brechas) · Playbook operativo v2.0 · Diagrama de flujo granular
Playbook de DDoS	SOC-IR-043	Informe de diseño · Playbook operativo v1.0 · Diagrama de flujo granular

10.3 Próximos Pasos Recomendados

Para un equipo que quiera aplicar lo aprendido en un entorno real, se recomiendan los siguientes pasos por orden de prioridad:

14. Parametrizar los umbrales de activación del DDoS (Gbps / Mpps) con valores reales de la organización y construir o actualizar las baselines de tráfico mensuales.
15. Documentar el contacto 24/7 con el ISP y el proveedor anti-DDoS, verificar los SLAs de activación y probar la activación en modo de prueba al menos una vez al año.
16. Documentar el nombre y teléfono directo del responsable de Finanzas/Tesorería para el escalado BEC en el playbook de Phishing.

17. Realizar un tabletop exercise del escenario BEC y del escenario de fallo del SOAR en ransomware, con todos los roles de la sección 4 de cada playbook.
18. Verificar que los backups son inmutables (WORM), están aislados de la red de producción y que el procedimiento de restauración ha sido probado en los últimos 90 días.
19. Establecer las métricas de MTTD, MTTC y MTTR como KPIs del equipo con seguimiento mensual y reporte al CISO.
20. Planificar la revisión de todos los playbooks cada 6 meses o tras cualquier incidente real que los active.

"Un incidente bien gestionado no es el que no ocurrió. Es el que el equipo supo cómo responder."
